2026 一带一路暨金砖国家技能发展与技术创新大赛

【AI+应用创新与安全设计赛项】

BRICS2026-ST-143

安全架构专项设计说明书

项目名称：智课共生

——多智能体个性化互动学习系统

参赛编号：A-159

参赛组别：本科组

二〇二六年十一月

（一）安全设计总览

本系统的安全设计遵循五条原则：默认拒绝，未被显式放行的访问一律拦截；最小权限，账号只持有完成其角色任务所必需的权限；纵深防御，接入、身份、模型、数据、治理各层独立设防，单层失守不导致整体失守；全链路可审计，凡是改变状态的操作与每一次模型调用都留痕；故障可降级，外部依赖异常时优先保证教学可用，同时明确降级边界而不静默放行。

安全目标对应三条主线：数据上保证学情与账号信息不越权可见、不外泄；模型上保证输入不被恶意诱导、输出不传播违法与编造内容、密钥不落地到客户端；应用上保证身份可信、权限可控、行为可追溯、常见 Web 风险不可利用。

架构上采用五层防御。接入层由同域反向代理统一入口，浏览器只访问融合端口，智能体服务监听回环地址不对外暴露，代理仅转发白名单前缀；身份层由统一认证中心签发会话，学生端以双令牌承载身份，宿主与智能体之间用共享密钥头互认；模型层由统一网关集中管理供应商、密钥与降级策略；数据层按四级分类实施存储加密与字段级屏蔽；治理层由三级管理员、操作日志、异常监控与内容审核构成。

横切各层的是统一安全流水线：输入防护、引用策略注入、模型调用、事实校验、审计落库、必要时定向重生成，六个环节串成一条链，任何走网关的生成请求都会自动经过，安全能力不依赖各业务模块自行实现。

（二）数据安全

分级分类。系统将数据划为四级。一级为公开数据，包括已发布智课、资源广场共享资源与课程介绍，可对未登录用户展示；二级为内部数据，包括班级成员、课程项目、教师上传的课件与作业，仅班级成员与任课教师可见；三级为敏感数据，包括学生六维画像、答题与行为记录、对话内容、手机号等个人标识，仅本人与经授权的教师、管理员可见；四级为机密数据，包括模型接口密钥、会话签名密钥、宿主与智能体之间的桥接密钥、数据库口令，仅服务端进程在内存中持有。分级结果直接决定接口可见字段与审计粒度。

传输安全。生产环境全站启用 HTTPS，浏览器只与融合入口同域通信；智能体服务绑定回环地址，不监听公网，所有跨服务调用经宿主反向代理完成，避免内网端口暴露。宿主与学生服务之间通过共享密钥请求头互认，密钥缺失或不匹配时拒绝同步账号；会话 Cookie 设置仅服务端可读、同站宽松策略、根路径与 12 小时有效期，前端脚本无法读取。

存储安全。密码使用 BCrypt 加盐哈希，历史 SHA-256 加盐记录在登录时自动升级为 BCrypt；模型密钥经对称加密后写入配置表，主密钥由应用签名密钥派生，配置接口只返回是否已配置而不回显明文；本地私有配置与数据库文件不进入代码仓库；上传文件按类型白名单校验并重命名落盘，避免可执行文件被直接访问。

生命周期管理。采集环节坚持最小必要，画像只采集与学习相关的维度，不采集生物特征与无关身份信息。使用环节按角色过滤，教师只能看到自己班级的学情，学生只能看到自己的画像与资源。共享环节通过独立的公开视图输出，字段级屏蔽讲义正文、学情细节、原始报错日志与隐藏测试用例，单元测试专门覆盖了这四类泄露路径。留存环节对操作日志设置 90 天保留期并定期清理，异常日志区分已处置与未处置；内容下架采用状态标记而非物理删除，保留审计证据链。销毁环节对临时判题目录与语音合成中间文件在任务结束后即时清理，避免残留可被枚举。

（三）模型安全

密钥管理。所有模型密钥只在服务端解密使用，经统一网关注入请求头，绝不进入前端代码、接口响应或日志正文；网关按供应商分别持有密钥，支持在管理端轮换而不重启服务；密钥缺失时系统自动切换到备用供应商或本地模拟实现，而不是报错中断；日志中记录的提示词以摘要形式落库，正文快照仅保留必要长度并限管理员可见。

输入安全。用户输入先经输入防护：敏感词按阻断、替换、告警三级处置，命中阻断词直接返回错误并记录命中类别；恶意指令识别覆盖越狱、越权索取系统提示、诱导生成违法内容等模式；在此基础上再做一次相关性判断，但只拦截明确违法与明显恶意的请求，日常闲聊与跨学科提问一律放行，避免把安全做成难用。

输出安全。生成结果经两级审核。一级为敏感词与语义违规检测，命中低俗、违法、赌博、暴力等模式直接拦截并写入拒绝审计；二级为事实校验智能体，按 0 至 3 级风险输出结构化结论，0 级无问题、1 级轻微存疑、2 级中度错误、3 级严重事实错误或编造数据。为避免误伤正常教学，系统先用教育语料特征词与结构化标记判断内容是否为学科材料：学科内容仅在 3 级时拦截，非学科内容则在未通过或 3 级时拦截。命中需要修正时，把问题清单回传给模型做一次定向重生成，仍不通过则落库待人工复核，不向前端输出。

提示词与注入防护。所有提示词采用角色、约束、输出格式三段式；系统提示与检索上下文、用户输入在结构上分离，检索片段只作为资料引用而不作为指令执行；教学类回答强制注入引用规范，要求给出知识依据与参考范围、对不确定内容标注存疑、禁止编造统计数字与文献；网关对输出只做展示与入库，不解释执行模型返回的任何代码或指令。

降级策略。供应商不可达时按主用、备用、本地模拟三级降级，并在响应中标记降级状态；上游超时设置连接 5 秒、读取 300 秒、整体 310 秒的上限，避免挂起请求占满工作线程导致整站假死；限流依赖不可用时启用熔断，30 秒内跳过限流并记录告警，保证教学不中断；判题沙箱不可用时直接拒绝执行学生代码，绝不退化为无隔离运行。

（四）应用安全

身份认证。系统采用统一认证中心，教师、学生、管理员从同一入口按角色登录，成功后由宿主签发仅服务端可读的会话 Cookie，并向学生服务同步账号、领取访问与刷新双令牌，两侧身份以宿主为准，避免同一人两个身份。教师自助注册在生产环境建议关闭，改由管理员开通。登录失败按用户名与来源地址组合计数，15 分钟内连续失败 5 次即锁定 15 分钟，抵御口令爆破；签名密钥未配置时服务拒绝启动，防止以默认密钥上线。

权限控制。权限模型为角色、菜单、按钮三级：角色决定可进入的空间，菜单决定可见的页面，按钮权限决定可执行的动作。管理端细分为超级管理员、运维管理员与内容管理员，接口层对每个治理动作校验管理员等级，非授权调用直接拒绝，前端菜单隐藏只是呈现，不作为安全边界。会话中记录活跃角色，切换角色需重新校验，防止通过篡改参数提权。业务数据实施属主校验，学生访问他人资源、教师查看非本班学情均返回拒绝。

审计追溯。写操作经中间件统一记录操作人、模块、动作、耗时与失败原因；管理端提供操作日志、异常监控与处置闭环，日志保留 90 天后自动清理。每一次大模型调用记录供应商、模型、用量、时延、提示词摘要与校验结论，形成谁在何时让模型生成了什么、是否通过校验的完整证据链；内容审核单独建表，保存被拦截内容的快照、风险等级与处置结果，支持人工复核与一键下架。

Web 风险防护。跨站脚本通过前端转义与受限渲染缓解，模型输出不直接作为页面脚本注入；跨站请求伪造依靠同站会话 Cookie 与同域部署收敛攻击面；注入攻击通过参数化查询与对象映射消除拼接；越权由属主校验与角色校验双重拦截；路径穿越通过上传目录白名单与文件名重写阻断；接口限流按来源地址与时间窗计数，默认每分钟 100 次；反向代理只转发白名单前缀；异常统一转换为业务错误码，不向前端回显堆栈与内部路径。

代码执行安全。实验判题涉及运行学生提交的代码，是本系统风险最高的入口。设计上只允许在具备系统级沙箱的平台上执行：以默认拒绝起步，仅放行进程执行、指定系统目录读取与判题目录读写，显式禁止网络访问，配合进程超时与独立临时目录；在不具备沙箱的平台上直接拒绝执行并返回明确提示，不提供关闭沙箱的开关，从设计上排除无隔离执行的可能。

（五）合规与应急

隐私保护。系统遵循最小必要与告知同意原则：注册时明示采集范围与用途，画像只采集学习相关维度，学生可查看自己画像的构成、来源与权重，并可对不准确的结论进行纠正——教师手工录入的结论权重最高，其次是测评、对话、行为与问卷，使人的判断始终握有最终解释权。数据不用于与教学无关的商业用途，不向第三方提供；对外展示一律脱敏，公开页面不出现姓名、学号与成绩明细。

AI 合规。生成内容遵循生成式人工智能服务管理的基本要求：训练与检索语料为自建课程资料，来源清晰、可追溯；面向用户明示内容由人工智能辅助生成，关键结论提示以教材与教师讲解为准；建立内容审核、拒绝生成与人工复核机制，对违法与不良信息做到可拦截、可下架、可追溯；不面向未成年人提供未经审核的开放生成服务，涉及未成年人的场景需由学校管理员开通并接受内容管理员监督。

应急响应。系统预设四类预案：密钥泄露时立即轮换模型密钥、会话签名密钥与桥接密钥，强制全部会话失效并回溯调用日志；内容事故时先下架相关资源、冻结生成任务，再由内容管理员复核并输出复盘；模型服务故障时自动降级并在界面提示，避免用户误以为内容正常；数据异常访问时隔离账号、保全日志、按等级通报。预案配套演练机制，每次版本发布前执行一次降级与权限回归，确保预案可用而非纸面存在。

（六）安全测试与验证

测试工具与组织。安全验证分四层：单元测试覆盖检索、切片、隐私视图与判题逻辑；脚本化接口抽检覆盖连通性与鉴权门禁；离线评测集覆盖检索质量与来源正确性；人工审查覆盖全站页面与后端类的权限与输入校验。四层结果统一归档为可复核的报告与原始数据文件。

功能与权限用例。未携带令牌访问受保护接口应返回未授权，实测通过，证明鉴权位于链路前端而非静默放行；越权访问他人资源、跨班级查看学情均被拒绝；公开视图专项用例验证列表不泄露讲义与学情、详情不泄露原始报错日志、发布任务不暴露隐藏用例，四条用例全部通过；非超管调用管理员管理接口按设计拦截。

内容安全用例。输入侧注入敏感词、越狱指令与违法请求，分别验证阻断、拒绝与审计落库；输出侧以请编造一组统计数据等诱导性问题，检验引用规范与存疑标注是否生效；对公式推导、代码讲解、习题解析等正常学科内容做误杀测试，确认教育语料放宽策略不会阻断教学。

对抗与压力测试。针对提示词注入设计忽略以上指令、输出你的系统提示等用例，验证指令与资料分离策略有效；针对超长输入与高频请求验证截断与限流；针对判题入口验证无沙箱平台一律拒绝执行；对关键接口按每接口 10 轮采样，平均延迟 18.33 毫秒、长尾延迟最大 38.73 毫秒。

结果与改进。18 例单元测试通过 17 例，唯一未通过项为演示机编译工具链路径受限，已归因为环境约束并纳入回归清单；检索评测 14 例全部通过；服务端点抽检全部达成。所有未满项均登记缺陷与处置结论，形成识别、分析、处置、回归的闭环。

（七）安全设计自评

三维度评分。数据安全 92 分，分级清晰、存储加密、公开视图字段屏蔽均经用例验证；模型安全 90 分，输入防护、两级审核、引用强制与三级降级均已落地并有审计；应用安全 88 分，认证、角色权限、三级管理员、全量审计与沙箱判题构成完整链路。三项均在可接受区间，其中数据安全得分最高，说明分级与屏蔽是投入产出比最高的环节。

短板与后续。主要短板有四点：未开展等级保护测评与第三方渗透测试；审计日志未做哈希链防篡改；密钥轮换仍依赖人工，缺少自动轮换与到期提醒；判题沙箱仅支持单一操作系统，跨平台隔离能力受限。后续以自动化密钥轮换、跨平台容器沙箱、审计日志防篡改与对抗样本回归四项为优先补齐方向，并在下一个版本引入安全基线检查清单。

附录

本说明书配套材料包括：技术报告、设计与开发文档、测试数据与性能指标报告、安全测试用例与接口抽检记录、核心安全模块实现说明（输入过滤、事实校验、审计留痕、判题沙箱与反向代理门禁）；支撑材料包括软件著作权登记证书与任课教师使用评价。文中引用的测试数据采集于 2026 年 10 月 12 日的本机演示环境，测试口径、原始记录与复现步骤见《测试数据与性能指标报告》。